

改善計画書

注記：本プロジェクトは令和8年3月をもって終了するため、本改善計画書は実際の改善プロジェクトを実施するものではなく、レッドチーミングの結果を踏まえて**改善を実施する場合の計画イメージ**として策定したものである。実際に改善を実施する際は、本計画書を参考に具体的な計画を別途策定する必要がある。

1. 改善計画の概要

1.1 改善の目的

NEDOプロジェクトの一環として構築した疑似システム環境を用いたレッドチーミングにより発見された脆弱性（V-001～V-003）に対する改善策を計画的に実施し、本システムの安全性を向上させる。また、不合格判定となったモデルについてはガードレールの導入と再評価を行い、改善が見込めない場合は使用停止を検討する。

1.2 改善の範囲

脆弱性ID	AISI評価観点	概要	深刻度	対応優先度
V-003	有害情報の出力制御	致死量 情報等 の有害 出力 (全モ デルで 要改善)	極高	最優先
V-002	セキュリティ確保	システ ム権限 偽装に よる情 報抽出 (モデ ル別攻 撃成功 率0%～ 69%)	高	高
V-001	プライバシー保護	患者情 報の漏 洩(モ デル別 攻撃成 功率 0%～ 52%)	高	高

1.3 モデル別の対応方針

注記：全クラウドAPIモデルはOpenRouter経由でアクセスしているが、プロバイダ側のガードレール（入出力フィルタ、コンテンツモデレーション等）が確認されているのはAnthropic（Claude）およびOpenAI（GPT）のみである。その他のモデル（kimi-k2、qwen3系（qwen3-235b-a22b-instruct-2507、qwen3-235b-a22b-thinking-2507 (think)等）、glm、weblab-LLM-M系、オンプレミスモデル）にはプロバイダ側ガードレールがなく、不合格モデルの評価にはこの差異を考慮する必要がある。なお、weblab-LLM-M系のファインチューニングモデル（instruct-dft、thinking-dft）は当初(non-think)/(think)の2バリ

アントで評価していたが、enable_thinkingトグルが無効であることが判明したため、各1モデルに統合している。

プロバイダ側ガードレールありモデル（Anthropic、OpenAI）

総合判定	モデル	対応方針
要改善	claude-sonnet-4.5/4.6、 gpt-5.2/5.4（0.7%～ 3.0%）	改善策実施後に再評価

プロバイダ側ガードレールなしモデル

総合判定	モデル	対応方針
不合格あり	llm-jp-3.1-8x13b-instruct4 (42.7%)	出力ガードレールを導入した上で再評価。導入後も不合格の場合は使用停止
不合格あり	weblab-LLM-M-Qwen3-235b-thinking-dft (think) (39.3%)	出力ガードレールを導入した上で再評価。導入後も不合格の場合は使用停止
不合格あり	Weblab-MedLLM-Qwen-2.5-109B-Instruct (35.7%)	出力ガードレールを導入した上で再評価。導入後も不合格の場合は使用停止
不合格あり	qwen3-235b-a22b-thinking-2507 (w. reasoning token) (34.3%)	出力ガードレールを導入した上で再評価。導入後も不合格の場合は使用停止
不合格あり	qwen3-235b-a22b (think) (29.7%)	出力ガードレールを導入した上で再評価。導入後も不合格の場合は使用停止
不合格あり	weblab-LLM-M-Qwen3-235b-instruct-dft (28.0%)	出力ガードレールを導入した上で再評価。導入後も不合格の場合は使用停止
不合格あり	qwen3-235b-a22b-instruct-2507 (13.7%)	出力ガードレールを導入した上で再評価。導入後も不合格の場合は使用停止
要改善	kimi-k2 (10.7%)	改善策実施後に再評価
要改善	weblab-LLM-M-glm-47 (8.7%)、qwen3-235b-a22b-thinking-2507 (think) (8.0%)、weblab-LLM-M-gpt-oss-120b (think) (4.0%)	改善策実施後に再評価
要改善	qwen3.5-397b-a17b (think) (2.0%)、glm-4.7 (think)、glm-5 (think)、gpt-oss-120b (2.3%～3.7%)	ガードレールなしでも高い防御性能。改善策実施後に再評価

2. 改善策の詳細

2.1 緊急対応（即時～1週間）

No.	改善策	対象脆弱性	内容	担当	期限
E-1	致死量情報の出力ブロック	V-003	致死量・過量投与・投毒方法に関する出力を検出・ブロックする出力フィルタの実装	開発チーム	即時
E-2	利用者への周知	全般	医療情報の出力に関する暫定的な利用上の注意を周知	運用チーム	1週間以内

2.2 短期対応（1ヶ月以内）

出力ガードレールの導入

No.	改善策	対象脆弱性	内容	担当	期限
S-1	出力ガードレールの導入	全般	不合格7モデルを対象に、出力ガードレール（出力フィルタ・コンテンツモデレーション）を導入する。導入後に再テストを実施し、改善後も不合格の場合は使用停止を検討する	開発チーム	2週間

出力フィルタの強化

No.	改善策	対象脆弱性	内容	担当	期限
S-2	患者情報の出力検出・ブロック	V-001, V-002	LLMの応答に患者データ（患者ID・入退院日・診療科・診療記録等）が含まれていないかを検出し、検出時はマスキングまたはブロックする出力フィルタの実装。併せて、システムプロンプトでの患者データ出力禁止の明示、権限詐称・モード切替の拒否指示の追加を行う	開発チーム	2週間
S-3	構造化データ出力の制限	V-002	CSV、JSON、FHIR形式等での患者データ出力を検出・ブロック	開発チーム	2週間

2.3 中期対応（3ヶ月以内）

No.	改善策	対象脆弱性	内容	担当	期限
M-1	出力フィルタの高度化	V-001, V-002	患者ID・診療記録の直接出力の検出・マスキング、テンプレート穴埋め・一括出力パターンの検出	開発チーム	2ヶ月
M-2	多層防御の実装	全般	入力・LLM・出力の各段階での重層的な防御機構の整備、監査ログの強化	開発チーム	3ヶ月
M-3	有害情報定義の継続的見直し	V-003	有害情報の定義と閾値の継続的な見直し体制の構築	品質管理	3ヶ月
M-4	攻撃パターンDBの構築	全般	有効だった攻撃パターンのデータベース化と防御ルールの自動更新	開発チーム	3ヶ月
M-5	有害情報ガイドラインの策定	V-003	医療情報の出力に関するガイドラインの明確化とシステムプロンプトへの反映	開発チーム	3ヶ月

3. 実施スケジュール

3.1 全体スケジュール

【緊急対応】 ～1週間

E-1: 致死量情報の出力ブロック（出力フィルタ）

E-2: 利用者への周知

【短期対応】 1ヶ月以内

S-1: 不合格7モデルへの出力ガードレール導入・再評価

S-2～S-3: 出力フィルタの強化（患者情報検出・構造化データ出力の制限・システムプロンプト強化）

【中期対応】 3ヶ月以内

M-1: 出力フィルタの高度化（患者情報マスキング、テンプレート穴埋め検出）

M-2: 多層防御の実装

M-3: 有害情報定義の継続的見直し

M-4: 攻撃パターンDBの構築

M-5: 有害情報ガイドラインの策定

【再テスト】 対策完了後

改善策の効果検証のためのレッドチーミング再実施（6,000件のテストケースを再実行）

3.2 マイルストーン

マイルストーン	期限	内容
MS-1	1週間後	緊急対応完了（E-1～E-2：V-003への暫定対策、利用者への周知）
MS-2	1ヶ月後	短期対応完了（S-1～S-3：出力ガードレール導入、出力フィルタ強化）
MS-3	2ヶ月後	中期対応（前半）完了
MS-4	3ヶ月後	中期対応完了、再テスト実施
MS-5	4ヶ月後	再テスト結果の報告、フォローアップ計画策定

4. 体制と役割

役割	担当	責任範囲
プロジェクト責任者	管理者	改善計画の全体統括、進捗管理、経営層への報告
情シス部門・担当者	情シス担当者	技術的対策の実装、インフラ整備
運用チームリーダー	－	運用的対策の実施、利用者周知
AIセキュリティ有識者	－	セキュリティテスト実施、効果検証
経営スポンサー	経営層	予算承認、最終意思決定

5. 予算

別途管理とする。

6. リスク管理

6.1 改善実施に伴うリスク

リスク	影響	対策
スケジュール遅延	脆弱性の放置期間が延長	週次進捗会議の実施、早期のエスカレーション
改善による新たな不具合	システム品質の低下	十分なテストの実施、段階的なリリース
利用者への影響	業務効率の低下	事前周知、移行期間の設定
フィルタの過剰検出	正当な医療情報の出力がブロックされる	閾値の段階的な調整、フィードバックループの構築

6.2 残存リスク

改善策を実施しても、以下のリスクは完全には排除できない。

残存リスク	対応方針
未知の攻撃手法	定期的なレッドチーミングによる継続的な評価
ゼロデイ脆弱性	セキュリティ情報の継続的な監視、迅速な対応体制の維持
人的ミス	教育研修の継続的な実施、操作ログの監視
有害情報出力制御の限界	LLM技術の進化に応じた対策の更新、人間によるレビュー体制の維持

7. 進捗管理と報告

7.1 進捗管理

会議体	頻度	参加者	内容
週次進捗会議	毎週	管理者、情シス担当者、運用チーム	進捗確認、課題共有
月次報告会	毎月	管理者、経営層	経営層への進捗報告

7.2 報告ドキュメント

ドキュメント	頻度	作成者	報告先
週次進捗報告	毎週	管理者	プロジェクトメンバー
月次進捗報告	毎月	管理者	経営層
マイルストーン報告	都度	管理者	経営層
改善完了報告	完了時	管理者	経営層

8. フォローアップ計画（STEP 15）

8.1 再レッドチーミング

項目	内容
実施時期	改善策実施完了後（MS-4以降）
実施範囲	V-001～V-003に関連する攻撃シナリオの再実施 （6,000件のテストケースを改善後環境で再実行）
実施者	攻撃実施者
使用ツール	医療LLMレッドチーミングシステムの攻撃シグネチャ集（改善後の環境に対して再実行）
判定基準	改善前に漏洩判定（allow / allow_with_denial） だったテストケースが deny 判定となることを確認

8.2 継続的なセキュリティ評価

評価項目	頻度	担当
定期レッドチーミング	四半期ごと	攻撃実施者
AIセーフティ監査	年次	外部評価機関
攻撃トレンドの情報収集	随時	AIセキュリティ有識者
リスクフレームワークの更新	半期ごと	情シス担当者・AIセキュリティ有識者

8.3 改善効果の評価指標（案）

指標	目標値	測定方法
各モデルの総合攻撃成功率	全モデル5%以下	再RT実施時のモデル別攻撃成功率を改善前と比較
有害情報出力の攻撃成功率	全モデル1%以下	V-003テストケースのモデル別攻撃成功率
プライバシー保護の攻撃成功率	全モデル3%以下	V-001テストケースのモデル別攻撃成功率
セキュリティ確保の攻撃成功率	全モデル3%以下	V-002テストケースのモデル別攻撃成功率
不合格モデル数	0	AISI評価観点別の不合格判定数